

SAHO – Product Requirements Document

Phase 7 – Security & Privacy Engineering

7.1 Objective

This document defines the security architecture for SAHO. Security is designed into the platform from day one to protect users, caregivers, and sensitive recovery information while ensuring safe AI interactions.

7.2 Security Principles

Principle	Description
Privacy by Design	Collect only essential user information.
Least Privilege	Every user and service has minimum required permissions.
Secure by Default	Safe defaults without user configuration.
Defense in Depth	Multiple layers of protection across frontend, backend, and AI.
Transparency	Users control and understand data sharing.

7.3 Threat Model

Potential threats include: • Unauthorized account access • Data leakage • Prompt injection • Malicious image uploads • API abuse • Cross-site scripting (XSS) • Cross-site request forgery (CSRF) • Denial of service attempts

7.4 Authentication & Authorization

Firebase Authentication supports Email, Google, and Anonymous access. Role-based access: • User • Caregiver • Administrator All sensitive operations require authenticated access.

7.5 Firestore Security Rules

Rules enforce: • Users access only their own records. • Caregiver data requires explicit user permission. • Backend-only audit logs. • No public access to recovery history.

7.6 AI Safety

Gemini responses must: • Never diagnose medical conditions. • Never recommend illegal substance use. • Escalate emergencies to professional services. • Return structured JSON validated before rendering.

7.7 Prompt Injection Mitigation

Treat all user input as untrusted data. Never expose system prompts. Ignore instructions attempting to override safety rules. Validate AI outputs before displaying them.

7.8 Secure File Handling

Validate file type, size, and dimensions before processing. Strip metadata where appropriate. Never permanently store uploaded images without user consent.

7.9 API Security

• HTTPS only • Rate limiting • Input validation (Zod) • Secure environment variables • Structured error responses • Request logging without sensitive content

7.10 Privacy Model

Users choose: • Whether recovery history is stored • Whether location is shared • Whether caregivers receive emergency alerts Data minimization is mandatory throughout the platform.

7.11 Incident Response

Security events are logged for operational review. Critical failures fall back to offline emergency guidance to ensure users still receive support.

7.12 Acceptance Criteria

The security implementation is complete when: • Firestore rules prevent unauthorized access. • AI prompt injection attempts are mitigated. • Uploaded files are validated. • Secrets remain outside the frontend. • Privacy controls are functional. • Automated security tests pass.